NIKTO

```
            NIKTO  BASICS AND USAGE
```

Nikto is a popular, opensource command line vulnerability scanner that checks web servers for security flaws, dangerous files, outdated software and configuration mistakes, helping penetration testers in their pentesting process (RECONNAISSANCE). It is a plugable web server and CGI scanner written in Perl, using rfp's LikbWhisker to perform fast security or information gathering.
As a security person when dealing with any tool at the first time it is mostly advisable to check the help menu or the manual page on how the tool is been used.

```
┌──(ben㉿kali)-[~]
└─$ nikto
- Nikto v2.5.0
---------------------------------------------------------------------------
+ ERROR: No host (-host) specified

   Options:
       -ask+               Whether to ask about submitting updates
                               yes   Ask about each (default)
                               no    Don't ask, don't send
                               auto  Don't ask, just send
       -check6             Check if IPv6 is working (connects to ipv6.google.com or value set in nikto.conf)
       -Cgidirs+           Scan these CGI dirs: "none", "all", or values like "/cgi/ /cgi-a/"
       -config+            Use this config file
       -Display+           Turn on/off display outputs:
                               1     Show redirects
                               2     Show cookies received
                               3     Show all 200/OK responses
                               4     Show URLs which require authentication
                               D     Debug output
                               E     Display all HTTP errors
                               P     Print progress to STDOUT
                               S     Scrub output of IPs and hostnames
                               V     Verbose output
       -dbcheck           Check database and other key files for syntax errors
       -evasion+          Encoding technique:
                               1     Random URI encoding (non-UTF8)
                               2     Directory self-reference (/./)
                               3     Premature URL ending
                               4     Prepend long random string
                               5     Fake parameter
                               6     TAB as request spacer
                               7     Change the case of the URL
                               8     Use Windows directory separator (\)
                               A     Use a carriage return (0x0d) as a request spacer
                               B     Use binary value 0x0b as a request spacer
        -followredirects   Follow 3xx redirects to new location
        -Format+           Save file (-o) format:
                               csv   Comma-separated-value
                               json  JSON Format
                               htm   HTML Format
                               nbe   Nessus NBE format
                               sql   Generic SQL (see docs for schema)
                               txt   Plain text
                               xml   XML Format
                               (if not specified the format will be taken from the file extension passed to -output)
       -Help              This help information
       -host+             Target host/URL
       -id+               Host authentication to use, format is id:pass or id:pass:realm
       -ipv4                 IPv4 Only
       -ipv6                 IPv6 Only
       -key+              Client certificate key file
       -list-plugins      List all available plugins, perform no testing
       -maxtime+          Maximum testing time per host (e.g., 1h, 60m, 3600s)
       -mutate+           Guess additional file names:
       -mutate-options    Provide information for mutates
       -nointeractive     Disables interactive features
       -nolookup          Disables DNS lookups
       -nossl             Disables the use of SSL
       -noslash           Strip trailing slash from URL (e.g., '/admin/' to '/admin')
       -no404             Disables nikto attempting to guess a 404 page
```

```
NIKTO(1)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                NIKTO(1)

NAME
       nikto - Scan web server for known vulnerabilities

SYNOPSIS

       nikto [options ... ]

DESCRIPTION
       Examine a web server to find potential problems and security vulnerabilities, including:

       •   Server and software misconfigurations

       •   Default files and programs

       •   Insecure files and programs

       •   Outdated servers and programs

       Nikto is built on LibWhisker (by RFP) and can run on any platform which has a Perl environment. It supports SSL, proxies, host authentication, IDS evasion and more. It can be updated automatically from the command-line, and
       supports the optional submission of updated version data back to the maintainers.

OPTIONS
       Below are all of the Nikto command line options and explanations. A brief version of this text is available by running Nikto with the -h (-help) option.

       -Cgidirs
           Scan these CGI directories. Special words "none" or "all" may be used to scan all CGI directories or none, (respectively). A literal value for a CGI directory such as "/cgi-test/" may be specified (must include trailing
           slash). If this is option is not specified, all CGI directories listed in config.txt will be tested.

       -config
           Specify an alternative config file to use instead of the config.txt located in the install directory.

       -dbcheck
           Check the scan databases for syntax errors.

       -Display
           Control the output that Nikto shows. See Chapter 5 for detailed information on these options. Use the reference number or letter to specify the type, multiple may be used:

           1 - Show redirects

           2 - Show cookies received

           3 - Show all 200/OK responses

           4 - Show URLs which require authentication

           D - Debug Output

           V - Verbose Output

       -evasion
           Specify the LibWhisker IDS evasion technique to use (see the LibWhisker docs for detailed information on these). Use the reference number to specify the type, multiple may be used:

           1 - Random URI encoding (non-UTF8)

           2 - Directory self-reference (/./)

           3 - Premature URL ending

 Manual page nikto(1) line 1 (press h for help or q to quit)
```

Having a fair knowledge on how the tool is been used my checking the manual page or the help session aids in a successful usage of the tool.

```
┌──(kali㉿Kali)-[~]
└─$ nikto -h ip_list.txt
- Nikto v2.5.0
---------------------------------------------------------------------------
---------------------------------------------------------------------------
---------------------------------------------------------------------------
+ Target IP:          10.6.6.13
+ Target Hostname:    10.6.6.13
+ Target Port:        80
+ Start Time:         2025-12-20 19:14:01 (GMT0)
---------------------------------------------------------------------------
+ Server: Apache/2.4.10 (Debian)
+ /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-
US/docs/Web/HTTP/Cookies
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozill
a.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render th
e content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/
web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Apache/2.4.10 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is th
e EOL for the 2.x branch.
+ /config/: Directory indexing found.
+ /config/: Configuration information may be available remotely.
+ /docs/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-ac
cess-to-iconsreadme/
+ /login.php: Admin login page/section found.
+ 8084 requests: 0 error(s) and 9 item(s) reported on remote host
+ End Time:         2025-12-20 19:14:16 (GMT0) (15 seconds)
---------------------------------------------------------------------------
```

```
┌──(kali㉿Kali)-[~]
└─$ nikto -h 172.17.0.2 -o scan_result.html
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          172.17.0.2
+ Target Hostname:    172.17.0.2
+ Target Port:        80
+ Start Time:         2025-12-20 19:25:33 (GMT0)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/
Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the
site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerab
ilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file n
ames. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698e
bdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x
branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-commun
ity/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?n
ame=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP req
uests that contain specific QERY strings. See: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP req
uests that contain specific QERY strings. See: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP req
```

From the above diagrams above it was shown that by the help of the help page or the manual page we were able to use the tool to scan multiple host and also somehow redirected the

results into a different file.

file:///home/kali/scan_result.html

Kali Linux | Kali Tools | Kali Docs | Kali Forums | Kali NetHunter | Exploit-DB | Google Hacking DB | OffSec

172.17.0.2 / 172.17.0.2 port 80

Target IP	172.17.0.2
Target hostname	172.17.0.2
Target Port	80
HTTP Server	Apache/2.2.8 (Ubuntu) DAV/2
Site Link (Name)	http://172.17.0.2:80/
Site Link (IP)	http://172.17.0.2:80/

URI	/
HTTP Method	GET
Description	/: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
Test Links	http://172.17.0.2:80/ http://172.17.0.2:80/
References	
URI	/
HTTP Method	GET
Description	/: The anti-clickjacking X-Frame-Options header is not present.
Test Links	http://172.17.0.2:80/ http://172.17.0.2:80/
References	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
URI	/
HTTP Method	GET
Description	/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a differe